

IT SECURITY CONSULTANCY

Acme Corp - Vulnerability Assessment & Penetration Testing (VAPT)
POC

Version	Date	Authors	Approver
Draft 1.0	27-JUL-2026	Fernando Bons Cybersecurity Expert	Jamal Mekdachi VP, Operations

CONTENTS

1 Executive Summary

1.1 Introduction

1.2 Findings and Recommendations

1.3 Risk Assessment and Impact on Business

2 Methodology and Scope

2.1 Cyberteq Security Assessment Methodology

2.2 Cyberteq Vulnerability Rating Guide

2.3 Scope

2.4 Out of Scope

2.5 Testing Methodologies

2.6 Test Cases

3 Findings and Recommendations

3.1 Recommendations Naming Convention

3.2 Vulnerability Register

4 Tools and Licenses

1 Executive Summary

1.1 Introduction

Cyberteq performed a security assessment on Acme Corp web applications. Vulnerability assessment and penetration testing (VAPT) activities were conducted through a VPN to reach the internally hosted applications. The security assessment was carried out during the period from 17th June 2026 to 24th June 2026.

The main objective of this engagement was to identify security vulnerabilities within the in-scope applications, evaluate their potential business impact, and provide actionable recommendations to remediate the identified issues.

During the reconnaissance phase, Cyberteq testers gathered information about the target applications to understand the attack surface before performing automated and manual testing activities.

This report details each of the findings identified during the assessment, providing a clear explanation of the vulnerability, its impact on the business, and the recommendations required to remediate it.

1.2 Findings and Recommendations

During the security assessment of Acme Corp's infrastructure, 4 issues of different severity levels have been discovered, categorized, and reported upon. The following section summarizes the distribution of the identified findings by their severity level.

1.2.1 Findings by Severity

Severity	Count
Critical	2
High	2
Medium	0
Low	0
Informational	0

1.3 Risk Assessment and Impact on Business

The vulnerabilities identified during this assessment pose varying levels of risk to Acme Corp. If left unremediated, these findings could be leveraged by malicious actors to compromise the confidentiality, integrity, and availability of the organization's information assets, potentially resulting in financial loss, reputational damage, and regulatory non-compliance. Cyberteq recommends prioritizing remediation efforts according to the criticality of each finding described in this report.

2 Methodology and Scope

2.1 Cyberteq Security Assessment Methodology

Cyberteq follows a structured, phased methodology to ensure comprehensive coverage during the security assessment. The assessment is divided into the following four phases:

2.1.1 Information Gathering

In this phase, Cyberteq testers collect as much information as possible about the target environment through passive and active reconnaissance techniques to map the attack surface.

2.1.2 Automated Testing

In this phase, Cyberteq testers use industry-standard automated tools to quickly identify common and known vulnerabilities across the in-scope assets.

2.1.3 Manual Testing

In this phase, Cyberteq testers manually verify and exploit the identified vulnerabilities and discover complex logic flaws that automated tools cannot detect. Each finding is ranked as Informational, Low, Medium, High, or Critical based on its risk.

2.1.4 Deliverables

In this phase, Cyberteq consolidates all findings into a comprehensive report that includes an executive summary, detailed technical findings, impact analysis, and remediation recommendations.

2.2 Cyberteq Vulnerability Rating Guide

Cyberteq rates the severity of each identified vulnerability using the Common Vulnerability Scoring System (CVSS) version 3.1. The following metrics are considered when calculating the overall severity of a finding:

- 1. Attack Vector - Reflects the context by which vulnerability exploitation is possible (Network, Adjacent, Local, Physical).
- 2. Attack Complexity - Describes the conditions beyond the attacker's control that must exist to exploit the vulnerability.
- 3. Privileges Required - Describes the level of privileges an attacker must possess before successfully exploiting the vulnerability.
- 4. User Interaction - Captures the requirement for a human user, other than the attacker, to participate in the compromise.
- 5. Authentication - The number of times an attacker must authenticate to a target to exploit the vulnerability.
- 6. Exploitability - The likelihood of the vulnerability being attacked based on the current state of exploit techniques.
- 7. Scope - Whether a vulnerability in one component impacts resources beyond its security scope.
- 8. CIA - The impact to Confidentiality, Integrity, and Availability of the affected component.
- 9. Asset Rating - The business value and criticality of the affected asset.
- 10. Environment - Characteristics of the environment that may modify the base severity for the specific organization.

2.3 Scope

Security testing was conducted during the period from 17th June 2026 to 24th June 2026.

Activity	Details
Web Application Testing	All activities were performed remotely.
API Testing	All activities were performed remotely.

2.4 Out of Scope

- DoS attacks
- Client-side attacks

2.5 Testing Methodologies

2.5.1 Web Application Testing Methodology

The web application testing was conducted in accordance with the OWASP Testing Guide, focusing on the most critical web application security risks. The following categories were assessed:

- Injection
- Broken Authentication
- Sensitive Data Exposure
- Broken Access Control
- Security Misconfiguration
- Cross-Site Scripting (XSS)
- Insecure Deserialization
- Using Components with Known Vulnerabilities
- Insufficient Logging & Monitoring

2.6 Test Cases

2.6.1 Web Application Testing

3 Findings and Recommendations

This section presents the findings identified during the security assessment along with their associated risk criticality and recommended remediation actions. The criticality of each finding is classified according to the following criteria:

Criticality	Description
Critical	Business Critical - immediate action required.
High	Significant Security Threat - should be resolved quickly.
Medium	Area for Improvement - should be resolved.
Low	Area for Improvement - low priority, resolve when convenient.
Informational	Area for Improvement - promotes best practices.

3.1 Recommendations Naming Convention

Abbreviation	Meaning
REC	Recommendation
WPT	Web Application Penetration Testing
IPT	Internal Penetration Testing
EPT	External Penetration Testing
NAR	Network Architecture Review

For example, REC3_WPT3 refers to the 3rd recommendation for the 3rd finding from web penetration testing.

3.2 Vulnerability Register

Vulnerability	Exposure	Criticality	Vulnerability ID	Recommendation
Insecure Direct Object Reference (IDOR) in User Profile	Web	High	REC1_WPT1	Implement proper authorization checks. Use UUIDs instead of sequential IDs. Veri...
SQL Injection in User Authentication Endpoint	Web	Critical	REC2_WPT2	Use parameterized queries with prepared statements. Never concatenate user input...
Remote Code Execution via File Upload	Web	Critical	REC3_WPT3	Validate file contents by magic bytes, not extension. Store uploads outside webr...
Cross-Site Scripting (XSS) in Dashboard Search	Web	High	REC4_WPT4	Encode all user-supplied data before rendering. Implement Content Security Polic...

3.2.1 Insecure Direct Object Reference (IDOR) in User Profile

Description

The /api/v1/users/profile/{id} endpoint does not verify that the requesting user owns the profile being accessed, allowing any authenticated user to view and modify other users' profiles.	
CVSS Vector String	
-	
Impact	
-	
Affected Application	
node_eng_001_001	
PoC	
-	
Recommendation	
REC1_WPT1- Implement proper authorization checks. Use UUIDs instead of sequential IDs. Verify ownership before returning data.	

3.2.2 SQL Injection in User Authentication Endpoint	
Description	
The application fails to sanitize user-supplied input in the username parameter of the login endpoint before incorporating it into a database query. This allows an unauthenticated, remote attacker to execute arbitrary SQL commands, potentially leading to unauthorized access, data exfiltration, or complete database compromise.	Rating: Critical
CVSS Vector String	
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	
Impact	
Complete database compromise, data exfiltration, unauthorized access.	
Affected Application	
node_eng_001_001	
PoC	
POST /v1/auth/login HTTP/1.1 Host: api.example.com Content-Type: application/json { "username": "admin' OR '1'='1", "password": "anything" }	
Recommendation	
REC2_WPT2- Use parameterized queries with prepared statements. Never concatenate user input directly into SQL queries. Implement strict input validation and use a WAF as a defense-in-depth measure.	
3.2.3 Remote Code Execution via File Upload	

Description	
The file upload endpoint does not validate file contents, allowing an attacker to upload a malicious PHP file and execute arbitrary commands on the server.	Rating: Critical
CVSS Vector String	
-	
Impact	
-	
Affected Application	
node_eng_001_001	
PoC	
POST /v1/media/upload HTTP/1.1 Content-Type: multipart/form-data shell.php containing system(\$_GET['cmd'])	
Recommendation	
REC3_WPT3- Validate file contents by magic bytes, not extension. Store uploads outside webroot. Use a sandboxed processing pipeline.	

3.2.4 Cross-Site Scripting (XSS) in Dashboard Search

Description	
The search parameter on the dashboard is reflected in the page without proper encoding, enabling stored XSS attacks.	Rating: High
CVSS Vector String	
-	
Impact	
-	
Affected Application	
node_eng_001_002	
PoC	
-	
Recommendation	
REC4_WPT4- Encode all user-supplied data before rendering. Implement Content Security Policy headers. Use DOMPurify on the frontend.	

4 Tools and Licenses

Cyberteq testers used below tools in the Vulnerability Assessment:

- Burp Suite Pro
- Nmap
- Nuclei
- FFuf